sensitive data. Its role is limited to operating within the boundaries already established by authorization.

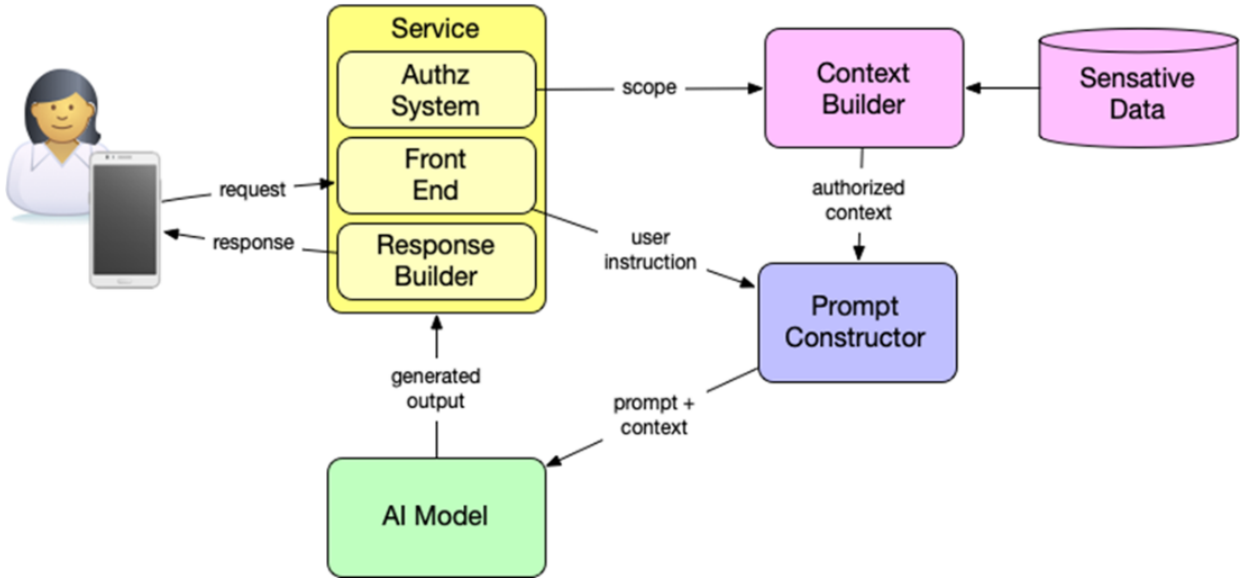


Figure 17.2 AI-assisted request handling. In this architecture, authorization is evaluated before any AI interaction. The authorization system determines the scope of access and produces an authorized context, which is then used to construct prompts for the language model. Sensitive data is never accessed directly by the AI. This separation ensures that access decisions remain deterministic and enforceable while still allowing AI systems to operate on authorized inputs.

This separation illustrates a broader principle in system design. Enforcement paths should be predictable and limited. Exploratory and interpretive tools must remain outside those paths. By excluding AI from the enforcement loop, ACME preserved the properties that ensure trustworthiness in authorization while still utilizing AI's strengths elsewhere.

The rest of this chapter builds on that boundary. Instead of asking how AI can decide access, we ask more productive questions. How can AI assist authors in creating better policies? How can it identify gaps and unintended consequences? How can it help teams understand what their authorization systems are really doing in production? How can authorization limit AI-enabled systems to ensure safety by construction?

17.2 Policy authoring and analysis with AI

Once ACME defined a clear boundary between authorization enforcement and AI-assisted workflows, focus shifted to where AI could deliver the most